



Assignment 3.2: Penetration Testing Plan

Christian Calipusan, Shivam Patel, Joshua Remington and Mikailou Nikiema

Shiley-Marcos School of Engineering (SMSE), University of San Diego

CYBR-514-01B: Cyber Engineering Research I

Professor Douglas Magedman

05/25/2026

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

Executive Summary

Four Point Cyber Consulting developed this Penetration Testing Plan for Design World to define a safe and controlled approach for validating selected vulnerabilities identified during the vulnerability assessment. Testing will focus only on approved systems within the Design World sandbox environment, including the Business Subnet, Website/DMZ Subnet, Public Subnet, and Transit and Services VLAN.

The penetration test will prioritize vulnerabilities that may support unauthorized access, privilege escalation, lateral movement, exposure of sensitive information, or service disruption. The purpose is not to exploit every finding, but to confirm which weaknesses present the most realistic risk to Design World's identity services, sensitive file storage, remote access path, and internal operations.

All testing activities will remain within the approved scope, testing window, and authorized methods. Destructive testing, denial of service activity, persistence mechanisms, and unauthorized access to data are prohibited. No penetration testing will begin until Design World provides formal written approval.

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

Table of Contents

1. Scope.....	3
2. Objectives.....	3
3. Background.....	4
4. Targeted Vulnerability Exploitation Plan.....	6
4.1 Windows Server 2022 Domain Controller.....	6
4.2 Windows Server 2022 File Server.....	8
4.3 Ubuntu 22.04 LTS Workstation.....	9
4.4 CentOS Stream 9 Web Server.....	11
4.5 OpenVPN Server.....	12
5. Testing Methodology.....	12
5.1 Test Environment and Duration.....	12
5.2 Testing Approach.....	13
6. Testing Techniques and Tools.....	14
6.1 Testing Techniques.....	14
6.2 Testing Tools.....	15
7. Rules of Engagement.....	17
8. Conclusion and Next Steps.....	17
9. Approvals.....	19

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

1. Scope

The scope of this Penetration Testing Plan is limited to the Design World sandbox environment and the systems identified in the approved vulnerability assessment. Testing will validate selected vulnerabilities and attack paths within the Public Subnet, Business Subnet, Website/DMZ Subnet, and Transit & Services VLAN. The penetration test will be performed from the approved Kali Linux testing system through the OpenVPN access path.

The penetration test will prioritize Critical and High findings from the vulnerability assessment. Medium, Low, and Informational findings may be reviewed when they support a realistic attack path, help validate a security boundary, or provide context for a higher-risk issue. This approach keeps the test focused on the areas most likely to affect Design World's intellectual property, remote access model, identity services, and internal operations.

2. Objectives

The objective of this Penetration Test Plan is to define how Four Point Cyber Consulting will safely validate the selected vulnerabilities identified during the vulnerability assessment. The plan is designed to give Design World a clear understanding of what will be tested, which systems are involved, what tools may be used, who will conduct the test, and what approval is required before testing begins.

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

The penetration test will focus on whether selected weaknesses could affect Design World's security posture if exploited by an attacker with access to the approved test path.

The goal is not to compromise the environment at any cost. Instead, the goal is to validate risk in a controlled manner, collect enough evidence to support remediation decisions, and help Design World understand which issues require the most attention before the hardening phase.

- Validate selected Critical and High vulnerabilities identified in the vulnerability assessment.
- Determine whether selected findings can support unauthorized access, privilege escalation, lateral movement, or exposure of sensitive information.
- Evaluate whether the approved network segmentation and VPN access model limit movement between systems.
- Assess whether identity, SMB, NFS, SSH, TLS, and remote administration weaknesses create realistic attack paths.
- Document testing evidence, business impact, and remediation recommendations for client review.

3. Background

The recent Vulnerability Assessment Report identified several areas of concern within the

 FOUR POINT — CYBER CONSULTING —		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

Design World sandbox environment that require further validation through penetration testing. The assessment showed that the highest-risk findings were concentrated on the internal business systems, particularly the Windows Server 2022 Domain Controller and File Server, where missing security updates, weak authentication settings, and insecure configuration items were identified. Additional findings were also observed across the Ubuntu workstation, Transit and Services VLAN, OpenVPN server, and CentOS web server, although not all systems presented the same level of risk.

This Penetration Testing Plan directly builds on those assessment results by focusing on selected weaknesses across the Business Subnet, Website/DMZ Subnet, Public Subnet, and Transit and Services VLAN. Not every vulnerability identified during scanning will be exploited. Instead, testing will prioritize findings that may present the highest risk to Design World's identity services, sensitive file storage, remote access path, internal movement, and service availability.

The penetration test is intended to simulate realistic attacker behavior within the approved sandbox scope. Testing will help determine whether selected vulnerabilities can be used to gain unauthorized access, elevate privileges, expose sensitive information, or move between systems. Because penetration testing introduces more risk than vulnerability scanning, all activity will remain limited to the approved targets, methods, and testing window defined in this plan. No testing will begin until Design World provides formal approval.

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

4. Targeted Vulnerability Exploitation Plan

The targeted vulnerability exploitation plan will focus on a limited set of vulnerabilities identified during the vulnerability assessment. Because the Design World environment contains multiple systems and a large number of scan findings, the penetration test will not attempt to validate every issue. Instead, the team selected vulnerabilities that are most relevant to Design World's risk profile, especially where they could affect identity services, sensitive file storage, remote access, internal movement, or system-level compromise.

Priority was given to Critical and High findings where available. Medium findings were included only when they support a realistic attack path or relate to authentication, encryption, segmentation, or internal exposure. CVE numbers are listed where they were directly identified in the vulnerability scan output. Where a CVE was not directly provided, the Nessus plugin ID, Microsoft KB, Ubuntu Security Notice, or advisory reference is used instead.

4.1 Windows Server 2022 Domain Controller

Target: DW-DC-OL-1

IP Addresses: 172.16.1.10 / 192.168.100.10

The Domain Controller is one of the highest-priority systems in the environment because

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

it supports centralized identity and access management. A successful compromise of this system could affect authentication, privileged access, and control over other domain-connected systems. The Business Subnet Nessus report identified 234 total findings on 172.16.1.10, including 22 Critical and 45 High findings.

Selected vulnerabilities for penetration testing:

1. **Windows Server 2022 Security Update Missing — KB5012604**

Severity: Critical

Reference: Nessus Plugin 159681 / Microsoft KB5012604

Testing Focus: Determine whether the missing security update creates an exploitable Windows Server weakness that could support remote code execution, privilege escalation, or unauthorized access.

2. **WinVerifyTrust Signature Validation Mitigation Not Enabled**

Severity: High

Reference: CVE-2013-3900 / Nessus Plugin 166555

Testing Focus: Evaluate whether weak signature validation configuration could allow improper trust of modified signed files or support execution of tampered content.

3. **Insecure Windows Service Permissions**

Severity: High

Reference: Nessus Plugin 65057

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

Testing Focus: Determine whether weak service permissions could allow a lower-privileged user to modify service behavior and escalate privileges.

4. Microsoft Windows LM / NTLMv1 Authentication Enabled

Severity: Medium

Reference: Nessus Plugin 63478

Testing Focus: Assess whether legacy authentication is enabled in a way that could increase credential exposure or support password hash attacks.

4.2 Windows Server 2022 File Server

Target: DW-FS-OL-1

IP Addresses: 172.16.1.20 / 192.168.100.20

The File Server is a priority target because it stores or supports access to Design World's sensitive design data. Weaknesses on this system could create risk to confidentiality, data integrity, and internal file access. The vulnerability results for the File Server include Windows patching gaps and authentication-related findings that are important to validate in a controlled penetration testing phase.

Selected vulnerabilities for penetration testing:

5. Windows Server 2022 Security Update Missing — KB5012604

Severity: Critical

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

Reference: Nessus Plugin 159681 / Microsoft KB5012604

Testing Focus: Determine whether missing Windows Server security updates could create a path for unauthorized access, privilege escalation, or system compromise.

6. SMB Signing Not Required

Severity: Medium

Reference: Nessus Plugin 57608

Testing Focus: Evaluate whether SMB traffic could be exposed to relay or man-in-the-middle style attacks, especially because this server supports file access and internal data storage.

7. Microsoft Windows LM / NTLMv1 Authentication Enabled

Severity: Medium

Reference: Nessus Plugin 63478

Testing Focus: Assess whether the use of legacy authentication could expose credentials or support unauthorized access attempts against file services.

4.3 Ubuntu 22.04 LTS Workstation

Target: DW-U22-OL-1

IP Addresses: 172.16.1.40 / 192.168.100.40

The Ubuntu workstation supports management and internal operations, making it relevant

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

to internal access and potential lateral movement. The vulnerability scan identified several Linux kernel and OpenSSL-related findings, along with exposed services on the Transit VLAN interface. These findings are important because they may create opportunities for local privilege escalation, unauthorized data access, or insecure administrative communication.

Selected vulnerabilities for penetration testing:

8. NFS Shares World Readable

Severity: High

Reference: Nessus Plugin 42256

Testing Focus: Determine whether exported NFS shares expose files to unauthorized users or systems within the environment.

9. Ubuntu 22.04 LTS / OpenSSL Vulnerabilities

Severity: High

Reference: Nessus Plugin 297271 / USN-7980-1

Testing Focus: Evaluate whether the identified OpenSSL weaknesses could affect encrypted communications, service security, or system exposure.

10. Unencrypted Telnet Server

Severity: Medium

Reference: Nessus Plugin 42263

Testing Focus: Determine whether Telnet is accessible and whether unencrypted

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

sessions could expose credentials or sensitive administrative activity. The Transit VLAN scan identified this finding on 192.168.100.40.

4.4 CentOS Stream 9 Web Server

Target: DW-CS9W-OL-1

IP Addresses: 172.16.10.50 / 192.168.100.50

The CentOS web server represents the Website/DMZ subnet and is included because it supports the public-facing layer of the Design World environment. The vulnerability assessment did not identify Critical or High findings for the Website subnet scan. The host showed 21 total findings, with one Low and 20 Informational results.

Because no Critical or High findings were identified on this system, it will not be a primary exploitation target during this phase. Testing may still include controlled validation of exposed services, SSH configuration, and DMZ boundary behavior if time permits and if approved by the client.

Although the CentOS web server will not be treated as a primary exploitation target, the penetration testing phase should still include limited validation of Website/DMZ accessibility. During the vulnerability assessment, Nikto and OWASP ZAP testing were limited by intermittent HTTP connectivity issues. Apache was confirmed to be running internally, but external access to port 80 initially failed. As a result, penetration testing

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

should validate whether the issue is caused by firewall filtering, routing restrictions, service binding, or segmentation controls between the Website/DMZ subnet and other network areas.

4.5 OpenVPN Server

Target: DW-OpenVPN-Server-OL-1

IP Addresses: 172.16.200.2 / 192.168.100.1

The OpenVPN server is the approved entry point into the Design World sandbox environment. The Public Subnet scan identified 21 total findings, with one Low and 20 Informational results on 172.16.200.2. The Transit VLAN scan also identified DNS cache snooping on 192.168.100.1 as a Medium finding.

Because the public-facing OpenVPN interface did not show Critical or High findings, this system will not be treated as a main exploitation target. However, the team may validate whether the DNS cache snooping issue contributes to internal reconnaissance or supports a broader attack path through the Transit VLAN.

5. Testing Methodology

5.1 Test Environment and Duration

Testing will be performed only in the Design World sandbox mirror environment. The

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

proposed testing duration is one week after written approval is received, with daily activity conducted during an approved testing window. The preferred testing window is Monday through Friday, 9:00 A.M. to 5:00 P.M. Pacific Time, unless Design World approves a different schedule.

Testing will be conducted from the approved Kali Linux assessment system through the OpenVPN tunnel. Any testing outside this path will require additional authorization.

5.2 Testing Approach

The selected approach is an informed white-box penetration test. The testing team has knowledge of the architecture, approved IP ranges, vulnerability assessment results, and business context. This approach is appropriate because the assignment is designed to validate known findings rather than discover the environment blindly.

The methodology will follow a controlled sequence:

Phase	Description
Pre-Test Authorization	Confirm signed approval, testing window, communication contacts, emergency stop process, and allowed tools.
Discovery Confirmation	Confirm live hosts, open services, and network reachability without expanding scope beyond approved assets.
Targeted Validation	Validate selected vulnerabilities from the Nessus reports and determine whether exploit conditions appear present.
Controlled Exploitation	Perform limited exploitation only where approved and where the risk of disruption is acceptable.

 FOUR POINT — CYBER CONSULTING —	Penetration Testing Plan	Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	05/25/26		

Attack Path Analysis	Determine whether validated weaknesses could support privilege escalation, lateral movement, or data exposure.
Cleanup and Reporting	Remove test artifacts, collect evidence, document limitations, and provide remediation recommendations.

Testing will stop if a technique appears likely to disrupt a critical service or move beyond approved scope.

6. Testing Techniques and Tools

6.1 Testing Techniques

- a. **Network Service Validation:** Confirm exposed services, ports, banners, and protocol behavior against the approved scan results.
- b. **Active Directory Security Review:** Review domain exposure, trust relationships, account visibility, and potential privilege paths using approved credentials or approved test accounts.
- c. **Configuration Weakness Validation:** Validate findings such as insecure service permissions, unquoted paths, weak protocols, and legacy authentication settings.
- d. **Web and DMZ Testing:** Review web server exposure, service configuration, and segmentation from the Website/DMZ subnet toward the Business subnet.
- e. **Controlled Exploit Validation:** Use safe proof-of-concept validation where approved to confirm exploitability without disrupting services.

 FOUR POINT — CYBER CONSULTING —		Penetration Testing Plan		Client	Design World
				Doc #	DW0004
Effective Date	05/25/26			Rev. #	Rev 1

- f. **Segmentation and Pivot Path Testing:** Assess whether the Transit VLAN and firewall boundaries prevent unauthorized movement between network areas.

6.2 Testing Tools

Tool	Use in Test Plan
Kali Linux	Approved testing platform used to access the sandbox through OpenVPN.
Nmap	Host discovery, service enumeration, and port validation.
Nessus	Reference scan data and follow-up validation where needed.
Metasploit Framework	Controlled exploit validation only where approved and safe.
enum4linux-ng / SMB tools	Windows and SMB enumeration for approved hosts.
BloodHound / SharpHound	Active Directory relationship and attack path analysis, subject to approval and safe collection settings.
Nikto / OWASP ZAP	Web server and application-layer checks for the Website/DMZ host.
Wireshark / tcpdump	Packet review for troubleshooting and evidence collection; not for unauthorized credential capture.
dnsrecon / dig / nslookup	DNS validation and cache snooping checks where applicable.
Searchsploit / NVD / vendor advisories	Exploitability research and vulnerability validation using trusted references.

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

7. Rules of Engagement

Penetration testing will begin only after Design World provides written approval. The signed approval authorizes Four Point Cyber Consulting to conduct testing only within the defined scope and testing window. The team will not expand testing to additional networks, assets, accounts, or cloud services without written approval.

All testing will be performed in a professional and ethical manner. The team will avoid destructive techniques, denial-of-service activity, persistence mechanisms, unauthorized data access, and any activity that would intentionally reduce availability. If a test path appears likely to affect system stability, the team will pause and notify the client before continuing.

The testing approach supports the broader project goal of aligning the Design World environment with NIST SP 800-171 and ISO 27000 principles. Compliance will be treated as a guide for security assurance and evidence collection, not as a claim that this penetration test alone proves full compliance.

8. Conclusion and Next Steps

This Penetration Test Plan establishes the approved approach for validating selected vulnerabilities within the Design World sandbox environment. The plan focuses on the systems and findings that appear most relevant to Design World's business risk, especially the internal Windows systems, Ubuntu workstation, remote access path, and

 FOUR POINT — CYBER CONSULTING —		Penetration Testing Plan		Client	Design World
				Doc #	DW0004
Effective Date	05/25/26			Rev. #	Rev 1

Transit VLAN services.

After client approval, Four Point Cyber Consulting will begin the penetration testing phase during the approved testing window. Testing will be performed carefully, with emphasis on validating risk rather than causing disruption. The results will be documented in a Penetration Test Report that includes testing activities, evidence, confirmed exploitability where applicable, business impact, limitations, and remediation recommendations.

Client approval is required before testing begins. Approval of this plan does not authorize testing outside the defined scope or any activity that is explicitly prohibited by the Rules of Engagement.

		Penetration Testing Plan	Client	Design World
			Doc #	DW0004
Effective Date	05/25/26		Rev. #	Rev 1

9. Approvals

Role	Printed Name	Signature	Date
Project Lead	Christian Calipusan	<i>Christian Calipusan</i>	05/25/26
Security Analyst	Shivam Patel	<i>Shivam Patel</i>	05/25/26
Security Engineer	Joshua Remington	<i>Joshua Remington</i>	05/25/26
Network Engineer	Mikailou Nikiema	<i>Mikailou Nikiema</i>	05/25/26
DW CEO			